

Batilis

Logiciel de gestion pour courtiers & AMO en travaux

Contrat de sous-traitance des données personnelles (DPA)

Conclu en application de l'article 28 du RGPD. Version du 16/09/2026.

Le Responsable de traitement (ci-après « le Responsable »)

[Dénomination], [forme juridique], SIRET [_____], [adresse], représenté(e) par [nom et qualité du représentant].

Le Sous-traitant (ci-après « le Sous-traitant »)

Anne-Lise Caillet, éditrice de l'application Batilis, entreprise individuelle (micro-entrepreneur), SIRET 990 409 781 00020, 22 rue Ramade, 13500 Martigues.

Contact protection des données : anne-lise.caillet@outlook.com

Article 1. Objet

Le présent contrat, conclu en application de l'article 28 du RGPD et de la loi n° 78-17 du 6 janvier 1978 modifiée (Loi Informatique et Libertés), encadre les traitements de données à caractère personnel que le Sous-traitant réalise pour le compte et sur les instructions du Responsable, dans le cadre de la mise à disposition de l'application Batilis.

Il complète les Conditions Générales de Service liant les parties et prévaut, pour les questions de protection des données, en cas de contradiction.

Article 2. Description du traitement

Élément	Description
Nature des opérations	Collecte (par saisie du Responsable et par dépôt du client final dans son espace), stockage, structuration, consultation, mise à disposition, transmission aux sous-traitants ultérieurs listés à l'article 4, envoi d'e-mails aux personnes concernées pour le compte du Responsable, hébergement, sauvegarde, suppression.
Finalités	Fournir au Responsable les fonctionnalités de gestion de son activité (dossiers clients, artisans, rendez-vous, comptes rendus, documents, planning, facturation de ses propres prestations, espace client).
Durée	Durée des Conditions Générales de Service ; suppression ou restitution en fin de contrat dans les conditions de l'article 7. Les sauvegardes chiffrées de l'hébergeur de base de données sont conservées 7 jours glissants (plan Pro Supabase) et s'effacent par rotation.
Catégories de personnes	Clients finaux du Responsable et co-titulaires du foyer, artisans et leurs représentants, apporteurs d'affaires, utilisateurs professionnels du Responsable.
Catégories de données	Identité et coordonnées, adresses de domicile et de chantier, coordonnées bancaires des artisans, documents d'entreprise (Kbis, assurances, RIB), devis, factures et procès-verbaux, photos de chantier, contenus de rendez-vous et de comptes rendus, échanges de messagerie, et — lorsque le Responsable utilise la fonction de dictée — enregistrements audio de visite et leur

Élément	Description
	transcription.

Catégories particulières. Aucune donnée relevant de l'article 9 du RGPD ne doit être saisie dans les champs libres ni prononcée pendant un enregistrement, et le Responsable s'engage à sensibiliser ses utilisateurs en ce sens. Il est expressément informé qu'une visite de chantier et les notes qui s'y rapportent peuvent en faire apparaître sans que cela ait été recherché — adaptation d'un logement à un handicap ou à une perte de mobilité, composition et situation du foyer, difficultés financières, dossiers d'aides. Il lui appartient d'en tenir compte dans l'information qu'il délivre aux personnes concernées et de veiller à ce que de tels éléments ne soient pas consignés lorsqu'ils ne sont pas nécessaires à la prestation.

Enregistrements audio. La fonction de dictée n'est activée que sur action de l'utilisateur.

L'enregistrement est transmis au service de transcription sur son point d'accès européen et avec exclusion de toute conservation, puis supprimé du stockage immédiatement après la transcription, que celle-ci ait réussi ou échoué ; seule la transcription textuelle est conservée, rattachée au compte rendu. Le Responsable fait son affaire de l'information et, le cas échéant, du recueil de l'accord des personnes présentes lors de l'enregistrement.

Article 3. Obligations des parties

Le Sous-traitant s'engage à :

1. Traiter les données uniquement pour les finalités prévues et sur instruction documentée du Responsable. Il ne réutilise en aucun cas les données pour ses propres finalités (notamment : statistiques produites à des fins commerciales, marketing, ou entraînement de modèles d'intelligence artificielle).
2. Garantir la confidentialité : toute personne autorisée à traiter les données est soumise à une obligation de confidentialité.
3. Mettre en œuvre les mesures de sécurité appropriées (article 32 RGPD) décrites à l'Annexe 1.
4. Respecter les conditions de recours à un sous-traitant ultérieur (article 4 ci-dessous).
5. Aider le Responsable à donner suite aux demandes d'exercice des droits des personnes concernées (accès, rectification, effacement, limitation, opposition, portabilité). **Cette assistance est due en toute hypothèse et n'est subordonnée à aucune condition financière** dès lors qu'elle s'exerce au moyen des fonctions de l'application et des extractions que le Sous-traitant peut produire. Si la demande suppose un développement spécifique, le Sous-traitant en indique le délai et le coût, et exécute entre-temps la demande par les moyens dont il dispose déjà ; un désaccord sur ce coût ne suspend jamais l'assistance.
6. Aider le Responsable à garantir le respect de ses obligations de sécurité, de notification de violation, et d'analyse d'impact le cas échéant (articles 32 à 36).
7. **Notifier au Responsable toute violation de données dans un délai maximal de 48 heures** après en avoir pris connaissance, par e-mail à l'adresse de contact déclarée par le Responsable, avec la nature de la violation, les catégories et le volume approximatif de données et de personnes concernées, les conséquences probables et les mesures prises ou proposées. Lorsque ces éléments ne peuvent être réunis dans ce délai, le Sous-traitant notifie ce qu'il sait et complète au fur et à mesure, sans dépasser 72 heures pour l'information complète.
8. Selon le choix du Responsable, supprimer ou restituer toutes les données à la fin de la prestation, et détruire les copies existantes, dans les conditions de l'article 7 et sauf obligation légale de conservation.
9. Mettre à disposition du Responsable toute information nécessaire pour démontrer le respect de ses obligations et permettre des audits, dans les conditions suivantes : une fois par période de douze mois, sur préavis écrit de 30 jours, pendant les heures ouvrables, sans perturber l'exploitation du

service, par le Responsable ou un auditeur indépendant soumis à un engagement de confidentialité et n'étant pas un concurrent du Sous-traitant. L'audit ne porte ni sur le code source, ni sur les données d'autres clients du Sous-traitant. Les coûts sont supportés par le Responsable, sauf si l'audit révèle un manquement avéré du Sous-traitant à ses obligations, auquel cas ils sont à la charge de ce dernier. Une fréquence supérieure est admise si une autorité de contrôle l'exige ou à la suite d'une violation de données avérée.

10. Informer immédiatement le Responsable si, selon lui, une instruction constitue une violation du RGPD ou d'une autre disposition du droit de l'Union ou du droit français relative à la protection des données. Il peut suspendre l'exécution de l'instruction en cause jusqu'à confirmation écrite du Responsable.

Le Responsable s'engage à :

- Ne donner que des instructions documentées et licites, et garantir que la collecte des données saisies dans l'application et leur traitement reposent sur une base légale.
- Informer les personnes concernées du traitement de leurs données et recueillir leur accord lorsqu'il est requis, notamment avant tout enregistrement audio d'une visite.
- Veiller à ce qu'aucune donnée relevant de l'article 9 du RGPD ne soit saisie dans les champs libres ni prononcée pendant un enregistrement, et sensibiliser ses utilisateurs en ce sens.
- Fixer les durées de conservation applicables à ses données et mettre en œuvre les leviers que l'application met à sa disposition (archivage, clôture, expiration d'un accès client).
- Décider de l'ouverture d'un accès en consultation à un client final, en fixer la durée et la révoquer le cas échéant.
- Maintenir à jour l'adresse de contact à laquelle lui sont notifiées les violations de données, et traiter les demandes d'exercice des droits qui lui sont adressées, avec l'assistance prévue au point 5 ci-dessus.

Article 4. Sous-traitants ultérieurs

Le Responsable autorise le Sous-traitant à recourir aux sous-traitants ultérieurs suivants pour l'exécution du service :

Sous-traitant ultérieur	Service	Localisation du traitement	Encadrement
Supabase	Base de données, authentification, stockage des documents et photos	Union européenne — Irlande (région eu-west-1)	DPA du prestataire applicable de plein droit par l'acceptation de ses conditions de service ; données au repos dans l'UE
Vercel	Hébergement et exécution de l'application	France — Paris (région cdg1) pour l'exécution ; société de droit américain	DPA du prestataire applicable de plein droit, incluant les Clauses Contractuelles Types ; certification EU-U.S. Data Privacy Framework
Anthropic (Claude)	Génération assistée de comptes rendus de visite et de courriers ; extraction de données à partir de devis, fiches techniques et documents d'artisans ; assistance à la planification et suggestions (actions, lots	API du prestataire ; société de droit américain	DPA du prestataire applicable de plein droit ; absence d'entraînement de modèles sur les données transmises ; non-conservation des données (Zero Data Retention) en cours de demande

Sous-traitant ultérieur	Service	Localisation du traitement	Encadrement
	et dates)		
Resend	Envoi des e-mails émis par l'application (invitations, réinitialisation de mot de passe, relances, demandes d'acompte, rappels de rendez-vous, diffusion de comptes rendus)	États-Unis pour le traitement principal	DPA du prestataire applicable de plein droit, incluant les Clauses Contractuelles Types. C'est le service d'envoi actif ; en son absence, l'application bascule automatiquement sur Microsoft Graph
Deepgram	Transcription des enregistrements audio de visite, lorsque la fonction de dictée est utilisée par le Responsable	Union européenne — point d'accès régional européen, qui traite et stocke dans l'UE et ne route pas hors région	Requêtes émises avec exclusion du programme d'amélioration des modèles : aucune conservation de l'audio ni du transcrit après la réponse, et aucun entraînement. Seules les métadonnées d'usage, sans contenu, sont conservées 90 jours. DPA du prestataire à formaliser — voir la mention « Statut des garanties » ci-dessous
Microsoft	Stockage documentaire (OneDrive), synchronisation du calendrier (Outlook), et envoi d'e-mails en solution de repli lorsque le service d'envoi principal est indisponible, si ces fonctions sont activées	Union européenne / États-Unis selon le service	Microsoft Products and Services Data Protection Addendum applicable de plein droit ; jetons d'accès chiffrés au repos
Google	Synchronisation du calendrier et rangement de documents (Google Drive, périmètre limité aux fichiers créés par l'application), si ces fonctions sont activées	Services Google (Union européenne / États-Unis)	Accès accordé par l'utilisateur lui-même au moyen de son propre compte, sous les conditions d'utilisation des API Google ; jetons d'accès chiffrés au repos
Apple / iCloud	Synchronisation du calendrier, si cette fonction est activée	Services Apple	Accès accordé par l'utilisateur au moyen d'un mot de passe d'application qu'il génère lui-même et peut révoquer à tout moment ; ce mot de passe est chiffré au repos

*** Statut des garanties : ** les DPA de Supabase, Vercel, Anthropic, Resend et Microsoft sont applicables de plein droit ; le Sous-traitant en conserve une copie datée, tenue à disposition du Responsable. L'exclusion du programme d'amélioration des modèles de Deepgram et son point d'accès européen sont acquis, inscrits dans le code et appliqués à chaque requête. Restent à obtenir, et sont à ce jour des engagements et non des faits acquis : la non-conservation des données chez Anthropic, et le DPA de Deepgram.*

Le Sous-traitant informe le Responsable de tout changement prévu concernant l'ajout ou le remplacement d'un sous-traitant ultérieur, par écrit et au moins 30 jours avant sa mise en œuvre. Le Responsable dispose de ce délai de 30 jours pour former opposition par écrit en motivant celle-ci par des considérations raisonnables de protection des données. En cas d'opposition, les parties recherchent une solution alternative ; à défaut d'accord dans les 30 jours suivants, le Responsable peut résilier les Conditions Générales de Service sans frais ni indemnité, par lettre ou courriel, avec effet à la fin du mois en cours et remboursement au prorata des sommes déjà réglées pour la période non courue. Chaque sous-traitant ultérieur est tenu aux mêmes obligations de protection des données que celles définies au présent contrat.

Article 5. Transferts hors Union européenne

Le stockage des données — base de données, authentification, documents et photos — est situé dans l'Union européenne (Irlande). L'exécution de l'application est configurée en France (Paris) ; cette configuration est vérifiable à tout moment sur le déploiement en production.

Les transferts hors Union européenne susceptibles d'intervenir sont les suivants, et aucun autre : l'assistance à la rédaction (Anthropic), l'envoi des e-mails (Resend), et, si le Responsable active ces fonctions, certains services Microsoft ou Google. Par ailleurs, Vercel étant une société de droit américain, ses journaux d'exécution et ses fonctions de plateforme peuvent donner lieu à un accès depuis les États-Unis, indépendamment du lieu d'exécution.

La transcription des enregistrements audio ne constitue pas un transfert hors Union européenne : elle emprunte le point d'accès européen du prestataire, qui traite et stocke dans l'Union. En cas d'indisponibilité de cette région, la requête échoue ; elle ne bascule pas ailleurs.

Ces transferts sont encadrés par les Clauses Contractuelles Types intégrées aux accords de traitement des prestataires concernés et, pour Vercel, par sa certification EU-U.S. Data Privacy Framework.

Article 6. Sécurité et localisation

Les mesures techniques et organisationnelles sont décrites en Annexe 1. Elles incluent notamment le cloisonnement des données par organisation au niveau de la base de données, le chiffrement des secrets d'accès au repos, l'authentification déléguée à un service spécialisé, le contrôle d'accès par rôle vérifié côté serveur, et l'accès aux fichiers par liens signés à durée limitée.

Article 7. Sort des données en fin de contrat

À la fin de la prestation, le Responsable choisit, par écrit et dans les 30 jours suivant la fin du contrat :

- soit la restitution de ses données ;
- soit leur suppression définitive.

Format de la restitution. La restitution prend la forme :

- d'un classeur au format .xlsx regroupant l'intégralité des données structurées de l'organisation du Responsable, réparties par onglet (clients, artisans, dossiers, devis, factures, rendez-vous, comptes rendus, messages, données financières), dans la limite de 50 000 lignes par onglet ;
- et, pour les documents et photos stockés, d'une remise sur support ou par lien de téléchargement, organisée par dossier. Le Responsable est informé que cette seconde remise n'est pas automatisée à la date du présent contrat et qu'elle est effectuée manuellement par le Sous-traitant dans le délai prévu ci-dessous.

Délai. La restitution, puis la suppression définitive des données et de leurs copies, interviennent dans un délai de 30 jours après la fin du contrat, ou après la réception du choix du Responsable si celui-ci est postérieur. Les sauvegardes chiffrées de l'hébergeur s'effacent par rotation dans les 7 jours qui suivent.

Sont réservées les données que le Sous-traitant doit conserver au titre d'une obligation légale, notamment comptable, qui sont alors isolées et ne font plus l'objet d'aucun traitement actif.

À défaut de choix exprimé par le Responsable dans le délai de 30 jours, le Sous-traitant procède à la suppression définitive après l'en avoir averti par écrit et lui avoir laissé un délai supplémentaire de 15 jours.

Article 8. Responsabilité

Chaque partie répond des dommages causés par un manquement à ses obligations au titre du RGPD, dans les conditions prévues par l'article 82 du Règlement. Le Responsable et le Sous-traitant se prêtent mutuellement assistance et se communiquent sans délai toute demande, réclamation ou action d'une personne concernée ou d'une autorité de contrôle.

Dans les rapports entre les parties, et sans que cela puisse être opposé à une personne concernée ni à une autorité de contrôle, la responsabilité contractuelle du Sous-traitant au titre du présent contrat est plafonnée au montant total des sommes versées par le Responsable au titre des Conditions Générales de Service au cours des douze mois précédant le fait générateur. Ce plafond ne s'applique ni en cas de faute lourde ou dolosive, ni aux amendes administratives prononcées par une autorité de contrôle à l'encontre de la partie qui en est personnellement responsable.

Article 9. Durée, droit applicable et juridiction

Le présent contrat prend effet à sa signature et demeure en vigueur pendant toute la durée des Conditions Générales de Service. Les obligations de confidentialité, de notification et de sort des données lui survivent jusqu'à leur complète exécution.

Il est soumis au droit français. À défaut de résolution amiable dans un délai de 60 jours à compter de la première réclamation écrite, tout litige relatif à sa validité, son interprétation ou son exécution relève de la compétence exclusive du Tribunal de commerce de Marseille.

Annexe 1. Mesures techniques et organisationnelles de sécurité

- **Cloisonnement par organisation.** Un mécanisme de sécurité au niveau de la base de données (Row-Level Security) est activé sur l'ensemble des tables, garantissant que chaque organisation n'accède qu'à ses propres données. Les vues utilisées par l'espace client portent un filtre équivalent, restreignant chaque client à ses seuls dossiers et faisant respecter la date d'expiration de son accès. La visibilité des agendas (personnel / partagé / société) est décidée au niveau de chaque enregistrement, et non par l'interface.
- **Chiffrement des secrets.** Les secrets d'accès aux services connectés — mot de passe d'application iCloud, jetons Google et Microsoft, jetons d'envoi d'e-mail — sont chiffrés au repos en AES-256-GCM, avec vecteur d'initialisation régénéré à chaque chiffrement, tag d'authentification et rotation de clés. Les clés ne résident jamais en base : elles proviennent de variables d'environnement serveur, et leur absence provoque l'échec de l'opération, sans repli en clair.
- **Authentification.** Elle est entièrement déléguée au service d'authentification de l'hébergeur de base de données. **Aucun mot de passe de compte n'est stocké ni manipulé par l'application, et aucun n'atteint une route serveur** : connexion, définition et changement de mot de passe s'effectuent directement entre le navigateur et le service d'authentification. Les sessions sont rafraîchies avant expiration et invalidées en cas de jeton mort.
- **Secrets saisis par l'utilisateur.** Une seule route serveur en reçoit un : le mot de passe d'application Apple servant à connecter un calendrier iCloud, généré par l'utilisateur sur son compte Apple. Il sert une fois en mémoire à valider la connexion, puis est chiffré avant enregistrement. Il n'est ni journalisé ni renvoyé au navigateur, et reste révoqué à tout moment depuis le compte Apple.

- **Contrôle d'accès.** Le rôle de chaque compte est lu en base côté serveur à chaque requête, jamais dans le jeton ni depuis le navigateur. L'appartenance d'un dossier à l'organisation de l'appelant est vérifiée avant tout accès. Un compte peut être désactivé, ce qui interrompt sa session en cours.
- **Stockage documentaire.** Les deux espaces de stockage (documents et photos) sont privés : aucune URL permanente n'existe. L'accès se fait exclusivement par liens signés à durée limitée — une heure pour la consultation dans l'application, dix minutes pour la transmission d'un audio au service de transcription, une heure pour le téléchargement groupé des photos d'un chantier.
- **Journalisation et messages d'erreur.** Les messages affichés aux utilisateurs et aux clients finaux sont rédigés en français et ne laissent filtrer aucun nom de table, de colonne ni de contrainte de la base ; le détail technique reste dans les journaux serveur.
- **Hébergement.** Base de données, authentification et stockage dans l'Union européenne (Irlande) ; exécution de l'application en France (Paris). Sauvegardes quotidiennes chiffrées conservées 7 jours glissants par l'hébergeur.

Signatures

Le Responsable	Le Sous-traitant
Nom :	Nom : Anne-Lise Caillet
Qualité :	Qualité : Éditrice de Batilis
Date :	Date :
Signature :	Signature :